

Auditoria de segurança - todos os projetos

Joao Abitante (@joaoabitante) | 10/07/2026

Escopo: pastas em Projetos + repos GitHub publicos + clones locais

2FA GitHub: CONFIRMADO OK

1. Resumo

- CRITICO (secret versionado): 0
- Falso positivo Contbit 'Bearer': filtrado (codigo de sessao legítimo)
- Premio Cripto publico: OK (MIT, sem secrets, SECURITY.md)
- Produtos de negocio (Contbit, Cofre, simuladores...): PRIVATE no GitHub
- Cofre BTC: private + gitignore .env/*.key + SECURITY-PRIVACY.md
- Elisao Fiscal: nao listado como publico
- 5+ repos locais sem gitignore (corrigido localmente nesta rodada)
- Pastas OneDrive sem git (Elisao zips, KYC-AML...): atencao a arquivos soltos

2. Faça nesta ordem

- [] 1. Confirmar no dashboard: cofre-btc-wallet e elisaofiscal = Private
- [] 2. Contbit: RLS no Supabase; so chave publishable no front; nunca service_role no repo
- [] 3. Contbit: NUNCA usar senha demo1234 em producao
- [] 4. Secret scanning + push protection na conta e repos
- [] 5. Branch protection main (force push bloqueado) nos repos com deploy
- [] 6. Commit/push dos .gitignore novos nos repos que receberam o arquivo
- [] 7. Email noreply nos commits novos
- [] 8. Desligar Wiki nos 7 repos publicos se nao usa
- [] 9. Fechar PRs Cloudflare do premio se deploy ja funciona

3. Por projeto (git local)

premioelisaofiscal - OK

- Publico OSS, MIT, sem secrets, CSP/PRIVACY/SECURITY
- Acao: PRs CF, wiki, branch protection

APP Contbit (contadores) - ATENCAO

- Private no GitHub (bom)
- URL Supabase + chave publishable hardcoded no app.js (padrao SPA)
- Seed SQL com senha demo demo1234 - so demo
- Acao: validar RLS; .env no gitignore (aplicado localmente)

Contbit SaaS (landing) - BAIXO

- Site estatico private; .gitignore criado localmente

cofre-btc-wallet - CRITICO por natureza / higiene OK

- Private; sem .env real no disco no scan
- Nunca tornar publico; seed so no dispositivo do usuario

Abitante de Pallet, Neurocompliance, C.CLASSTRIB, simulador-autista

- Private; faltava .gitignore - criado localmente nesta auditoria
- Neurocompliance: garantir zero dados reais de cliente no git

4. Publicos GitHub (7)

premioelisaofiscal (MIT) | abitanteventures | mundialTAX | copa2026 | aprendasobrekyc | compliance | trucolegends

Quase todos: Wiki ON, sem LICENSE (exceto Premio). Pages em varios.

5. Pastas OneDrive SEM git

- A Hora Elisao Fiscal - varios ZIP de release/whitelabel
- KYC-AML, Fator R, Mapa Mundial TAX - cuidado com dados/logica
- Nao guardar senhas Hostinger/tokens em .txt no OneDrive

6. O que o scan NAO achou (bom)

- Nenhum ghp_ / github_pat_ versionado
- Nenhuma private key PEM versionada
- Nenhum .env real trackeado nos 8 gits
- Nenhuma AWS AKIA no codigo

Relatorio completo em Markdown:

[premioelisaofiscal/docs/AUDITORIA-SEGURANCA-TODOS-PROJETOS.md](#)

Checklist da conta: [docs/Checklist-Seguranca-GitHub.pdf](#)